

Drafting the scoping documents and the strategy note

Writing to last: the scoping note, the roadmap, and the first stone of the strategy

Session objectives

By the end of this lab, the MERIDIAN dossier contains the Group CISO's scoping note, the group's multi-year roadmap with its budget framework, and the first subsection of the strategy note. What is learned here:

- **Draft** a scoping note: the document that delimits a mission before it overflows
- **Build** a multi-year roadmap whose milestones commit, backed by a budget whose base is explicit
- **Distinguish** scoping note, roadmap and strategy note, three documents beginners merge and managements want separate
- **Lay** the first stone of the document enriched at every session and defended at the final defense

Prerequisites

- The target governance from the previous lab: bodies, RACI, codified directives, arbitration rules. This lab does not rewrite them, it cites them.
- The gap analysis and its priorities: the roadmap is their orchestration over time.
- The module's grading scale, presented this morning: the strategy note carries 10 points in it, and it begins now.

Three documents, three functions, and the error that confuses them

The scoping note, first. The problem it addresses: a mission whose perimeter is not written down swells until failure; a Group CISO who has not been scoped ends up within six months responsible for everything, guilty of everything, and decider of nothing. The scoping note is the short document that delimits a mission: its purpose, its perimeter, its prerogatives, its counterparts, and its limits, what it does NOT cover. Its most useful mechanism is precisely that last section: writing down what is not done is the only rampart against the inflation of expectations. Its limit: a scoping note describes a mission, it does not prove the mission is advancing; that is the role of milestones, hence of the roadmap.

The roadmap, next, with its companion the **multi-year budget**. The problem: security is built over years, but budgeted by fiscal year; without a written trajectory, each annual budget starts from zero, at the mercy of recent incidents and moods. A multi-year roadmap orders the projects over time, with dated, verifiable milestones; the multi-year budget that accompanies it distributes the effort across the axes, and each distribution must specify its BASE, that is, exactly which envelope the percentages apply to, failing which the figures contradict each other from one meeting to the next. The context lends itself to this: according to the CESIN barometer published for 2023, 63 % of companies planned a budget increase allocated to protection measures; resources are rising, which makes arbitration more necessary, not less, because a budget that grows without a trajectory funds emergencies, never foundations. The genre's limit: a three-year roadmap is a hypothesis, not a prophecy; it gets revised, and that is a milestone like any other.

The strategy note, finally, and this one has a status of its own in the module: it is a graded deliverable, 10 points on the scale, and above all a CUMULATIVE document. Three pages at most, enriched for fifteen minutes at the end of each afternoon, until the final defense where it is defended. The problem it simulates is very real: a CISO maintains for management a living strategy document, which grows with the dossier without ever restating everything; knowing how to maintain it, adding without rewriting, amending without erasing, is a professional skill in itself. Its golden rule in this module: nothing is deleted, everything can be amended with one sentence of justification.

The test that separates the three documents: the scoping note answers "what is my mission?", the roadmap "what will be done, and when?", the strategy "where are we going, and why?". A sentence that answers a different question from its document's is in the wrong place.



Three documents, three questions, and the cross-reference that holds them together.

Exercise 1: the Group CISO's scoping note (15 minutes)

This is the document that should have existed before the Group CISO's first Monday. One page, five sections.

1. **Draft** the scoping note for the Group CISO's mission: the purpose (why this position exists, in two sentences anchored in the group's situation); the perimeter (the four subsidiaries, the division with the pooled IT department, the inter-subsidiary flows); the prerogatives (citing the three arbitration rules of the target governance, without rewriting them); the counterparts (the morning's bodies, each with what it is owed: proposal, reporting, alert); and the limits.
-

2. **Take care with** the limits section: at least three exclusions, realistic and useful (hint: the morning's CISO posture; what the CISO is NOT allowed to do in place of others is the best starting point).
-

Exercise 2: the roadmap and its budget (15 minutes)

The Executive Committee has approved the principle of a three-year trajectory, cut into six semesters, to bring the group to the target governance. Three strategic axes are settled for the group: the foundation of trust, OT/IT resilience, and security culture.

1. **Build** the roadmap: for each semester, one main objective, and three verifiable milestones at the 12, 24 and 36-month marks, consistent with priorities 1 and 2 of the gap analysis (hint: what is true at 12 months conditions the 24-month milestone).
-

2. **Propose** the budget weighting of the three axes, as percentages, with one line of justification per axis, and SPECIFYING the base of every figure put forward.
-

3. **Settle** two arbitrations submitted by management: the Santé and Éducation subsidiaries each request immediate reinforcement, from an exceptional envelope that can serve only those two; and a share of the existing envelopes must be reallocated toward modernizing obsolete infrastructure, for which the proposal is expected. Justify each of the two figures with an element from the dossier.
-

Strategy note (15 minutes)

The ritual begins here, and it will not stop until the final defense. The strategy note opens today with its first subsection: "Context and target governance". Half a page at most, and only three contents: the context, what the group is and why security is becoming a governance matter there, drawing on what the day has established without replaying it; the target governance, the bodies, the RACI and the arbitration rules, cited by reference to the charter, never copied; and the trajectory commitment, the adaptation of the framework PSSI by each subsidiary within six months, the roadmap's first enforceable milestone.

Two disciplines to adopt from this very first time, because they will be graded all the way through: the strategy note refers to the dossier's documents, it never duplicates them, which is what will allow it to fit in three pages nine sessions from now; and every statement must remain true over time or be amendable with one sentence, because nothing is deleted.

And to close the session, the sentence that hands it on: the governance written within the hour now decides WHO arbitrates and under which rules; what it still lacks is knowing exactly WHAT it reigns over, and that is the subject of the next session, the mapping of the group's information system, without which every decision in the charter would apply to unknown territory.

Answer keys and assessment criteria

Answer key for exercise 1: the reference scoping note

A condensed model, to compare afterwards. Purpose: the MERIDIAN group created the Group CISO position to give four subsidiaries with disjoint businesses a common security governance, after finding that security decisions were being made with no identified rule or level. Perimeter: the four subsidiaries and the Éducation & Territoires division with its pooled IT department, all inter-subsidiary flows, the relationship with the group's bodies. Prerogatives: those of the governance charter, suspensive veto with arbitration within 72 hours, validation of derogations within 48 hours, and the emergency isolation right of subsidiary CISOs, which the Group CISO equips and supervises. Counterparts: Executive Management, to whom the CISO proposes; the Executive Committee, to which the CISO reports, notably through the quarterly review; the Board of Directors, which the CISO informs via Executive Management; the Internal Auditor, whom the CISO informs and never directs. Limits, the three expected: the Group CISO does not set risk appetite, but proposes and informs it; administers no system, operations belong to the subsidiaries; does not stand in for subsidiary CISOs in the adaptation, but validates it. Did the note fit on one page? That too is a criterion: a long scoping note is a scoping note that has not chosen.

Answer key for exercise 2: the reference trajectory

The group's roadmap: three years, six semesters, including a 24-month priority phase concentrating most of the effort, the last 12 months consolidating and preparing what comes next. Milestones: at 12 months, the priority 1 gaps treated, the segmentation of Santé's biomedical equipment under way and the separation of Logistique's provider accounts completed, and the framework PSSI adapted by all four subsidiaries, the six-month commitment leaving six months of verification margin; at 24 months, Logistique's IT/OT segmentation operational, Territoires' logging centralized toward the SOC, and the executive dashboard fed without manual collection; at 36 months, the target governance fully applied and measured, subject to the trajectory revision which is itself a milestone. The reference weighting of the group's axes, base: the group's multi-year security budget: foundation of trust 40 %, because identities, access and authentication carry the two priority 1s; OT/IT resilience 35 %, Logistique's industrial core and Santé's biomedical equipment; security culture 25 %, the slowest and most durable investment. The two arbitrations: the exceptional envelope, base limited to those two subsidiaries, splits 60 % for Santé and 40 % for Éducation, the care mission and the state of the biomedical equipment weighing more than the real but less vital exposure of the Éducation fleet; and the reallocation toward modernizing obsolete infrastructure is set at 15 % of the existing envelopes, backed by the dashboard's obsolescence KRI, whose alert threshold is precisely what justifies divesting elsewhere. The common grammar of the two answers: every figure carries its base and its justification; a naked percentage is not an arbitration, it is an opinion in a suit.



The reference trajectory: three milestones that commit.

Answer key: the "Context and target governance" subsection, written as a model

"The MERIDIAN group, four subsidiaries with disjoint businesses and obligations, has equipped itself with a common security governance: bodies whose roles on risk appetite are now codified, a responsibility matrix with a single accountable owner, group directives and written arbitration rules, gathered in the governance charter to which this note refers. This governance answers the findings of the gap analysis attached to the dossier: security decisions hitherto made with no identified level or rule. Each subsidiary adapts the framework PSSI within six months; this adaptation constitutes the first milestone of the three-year roadmap approved in principle by the Executive Committee." Three long sentences or five short ones, no matter: context, reference to the documents, dated commitment. Nothing to delete later, everything amendable.

Assessment criteria

CRITERION	INSUFFICIENT	EXPECTED	EXCELLENT
Scoping note	Mission described without limits or counterparts	Five sections, prerogatives cited by reference	The limits genuinely protect the posture: does not set, does not administer, does not stand in
Roadmap	Vague or undated milestones	Three verifiable milestones at 12, 24, 36 months, consistent with the priorities	Same, with the dependency between milestones made explicit and the revision treated as a milestone
Budget	Percentages without base or justification	Weightings justified, bases specified throughout	Same, the two arbitrations backed by elements of the dossier (mission, KRI)
Strategy note	Copying of the dossier's documents	Half a page, three contents, references rather than duplications	Same, every statement durable or amendable with one sentence
Handover	Absent	The link to next session's mapping formulated	Same, articulated: a governance without a map reigns over unknown territory